# ReTrust

Score OT hardware for cyber risk before you buy it.

| | |
|---|---|
| GUIDE | How it works, how to run it, how to use it |
| VERSION | 0.1.0 · Apache-2.0 · Python 3.10+ |
| CORPUS | 3,937 CISA OT advisories · 28,951 product entries · 814 vendors |

QUICK START

1. **Install and build the database.** Python 3.10+ is the only requirement. About 165 MB and two minutes.

   ```
   $ git clone https://github.com/<you>/retrust.git && cd retrust
   $ python3 -m retrust.cli setup
   ```

2. **Find the product.** Advisories spell names their own way, so start by looking yours up.

   ```
   $ retrust search "S7-1500"
   ```

3. **Score it, or compare a shortlist.** Add `--html decision.html` for a report to attach to the requisition.

   ```
   $ retrust score --order-number 6ES7518-4AX00-1AB0 --version 3.1.6
   $ retrust compare --candidate "ABB|AC 800M" --candidate "Moxa|EDS-405A"
   ```

**Would rather be asked than type flags?** `retrust shell` gives you a menu covering everything here, prints the equivalent command each time, and saves the result as HTML, JSON or CSV when you are done. **Prefer a browser?** `retrust serve` puts search, scoring, comparison, alternatives and vendor profiles on `127.0.0.1:8765`, local to your machine and read-only.

**PREFER** ≥70 **CONDITIONAL** ≥40 **AVOID** below, or gated **NOT ASSESSED** unresolved

## 1 What it is for

Every other OT security tool analyses equipment you already own. Asset inventory platforms fingerprint what is on the wire; firmware tools take apart images you already have. ReTrust answers a different question, at the one moment a security decision is still cheap: **of these candidate PLCs, which one should go on the purchase order?**

It reads public advisory data, keys on the manufacturer order number a purchase requisition already contains, and shows the evidence behind every number it prints. It runs entirely offline against a local database, so a result is reproducible and a demonstration never depends on the network.

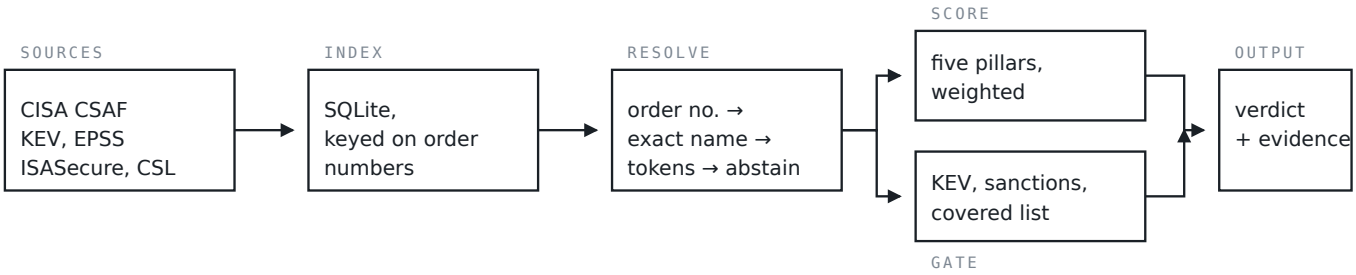
### Why order numbers, and not CPE

Every conventional vulnerability tool joins products to CVEs through CPE strings. Measured across all 28,951 product entries in CISA's OT advisory corpus:

| IDENTIFIER ON THE PRODUCT ENTRY | ENTRIES | SHARE |
|---|---|---|
| **CPE**, the join key conventional scanners use | 60 | 0.21% |
| Order number the advisory declares | 8,211 | 28.36% |
| Order number ReTrust recovers from the product name | 1,384 | 4.78% |
| **Order number, either** — what ReTrust keys on | 9,595 | 33.14% |
| Vendor name | 28,947 | 99.99% |

CPE is effectively absent from industrial advisory data, which is why general-purpose tooling performs so badly on OT gear. Declared order numbers are **137×** more available, and `6ES7518-4AX00-1AB0` is what a buyer types onto a requisition in the first place. Run `retrust eval` to recompute that table from your own database.

## 2 How it works




The pipeline. Gates sit outside the weighted score, so a disqualifying fact cannot be averaged away by good scores elsewhere.

### The four-rung resolution ladder

A buyer asks about "Siemens SIMATIC S7-1500, firmware 3.1.6". ReTrust decides which advisory products that refers to, strongest strategy first, and reports which rung answered.

| RUNG | METHOD | CONFIDENCE | MEASURED ACCURACY |
|---|---|---|---|
| 1 | Manufacturer order number | 0.98 | 100% |
| 2 | Vendor + product name | 0.90 | 99.8% |
| 3 | Vendor + all query words present | 0.70 | 100% |
| 4 | Abstain, with a typed reason | – | – |

A wrong answer about whether a PLC is vulnerable costs more than "needs review", so abstention is a feature rather than a failure.

### The five pillars

| PILLAR | WEIGHT | WHAT IT READS |
|---|---|---|
| Exploitation | 0.30 | CISA KEV, ransomware linkage, peak EPSS |
| Severity | 0.20 | worst CVSS, and how many flaws are critical |
| Patch availability | 0.20 | a fix, a workaround, or nothing |
| Vendor practice | 0.15 | whether advisories carry CVSS and CWE, own CSAF feed |
| Certification | 0.15 | IEC 62443 (ISASecure) and Common Criteria |

The weighted result is reported as a band: **PREFER** at 70 or above, **CONDITIONAL** at 40 or above, **AVOID** below. Weights and thresholds are yours to change — run `retrust config --init`.

REPORTED, BUT DELIBERATELY NOT SCORED

EVIDENCE CONFIDENCE. The share of findings whose version range parsed cleanly and which carry CVSS and EPSS data. Folding it into the score would mean "we have good data about how bad this is" *raises* the score, which is backwards. It tells you how far to trust the verdict, not how safe the product is.

## 3 Installing and running it

ReTrust needs Python 3.10 or newer and nothing else. There are no third-party packages, so there is nothing to resolve, nothing to pin, and no virtual environment to create.

TWO COMMANDS, FROM NOTHING TO A WORKING TOOL

```
$ git clone https://github.com/<you>/retrust.git && cd retrust
$ python3 -m retrust.cli setup
```

`setup` fetches CISA's OT advisory corpus, the KEV and EPSS exploitation feeds, and the certification and sanctions lists, then builds the local database. That is about 165 MB and a couple of minutes on a normal connection.

```
  [1/4] CISA OT advisories (~148 MB) ...
        3,938 advisory files
  [2/4] CISA Known Exploited Vulnerabilities ...
        1.8 MB
  [3/4] FIRST EPSS scores ...
        11.5 MB
  [4/4] Build the local index ...
        3,937 advisories, 28,951 products, KEV 1,726, EPSS 12,031

Ready.
```

**If it is interrupted, run it again.** Each step is skipped when its output is already there, so a dropped connection costs you only the step it dropped on. Downloads go to a temporary file and move into place once complete, so a half-fetched feed is never mistaken for a whole one.

| FLAG | EFFECT |
|---|---|
| `--offline` | Build from data already downloaded; fetch nothing |
| `--force` | Re-fetch sources even if they are present |
| `--skip-refresh` | Skip the certification and sanctions lists |
| `--data DIR` | Keep the data somewhere other than `data/` |

IT REFUSES TO FINISH ON AN INCOMPLETE DATABASE

If KEV or EPSS is missing, the exploitation gate cannot fire, and a product with a known exploited vulnerability would score as merely mediocre. Setup stops and says so rather than handing you a plausible-looking result.

### Getting the `retrust` command on your PATH

Optional. Everything above runs straight from the clone. To type `retrust` instead of `python3 -m retrust.cli`:

```
$ python3 -m venv .venv && source .venv/bin/activate
$ pip install -e .
```

The virtual environment is not optional on Debian, Ubuntu or Kali: those ship Python as an externally managed environment, and `pip install -e .` outside one fails with a PEP 668 error. Both forms are equivalent throughout this guide.

## 4 Using it

There are two ways to drive ReTrust, and they do the same things. Commands with flags suit a script or a pipeline. A menu suits somebody who would rather be asked.

### The menu

```
$ retrust shell
```

```
┌─────┬──────────────────────────────────────────────────────────────────┐
│   1 │ Search the corpus       find a vendor, product or order number   │
│   2 │ Score one product       verdict, pillars and the evidence        │
│   3 │ Compare candidates      rank several for one decision            │
│   4 │ Alternatives            others in the family, scored the same way│
│   5 │ Vendor profile          what the index holds on a manufacturer   │
│   6 │ Score a BOM file        a CSV or JSON list of candidates         │
│   7 │ Likely exploited        NIST LEV, has it probably happened already│
│   8 │ SSVC decisions          what buying this commits you to          │
│   9 │ What changed            re-score a saved result against today    │
│   s │ Save the last result    HTML, JSON or CSV                        │
├─────┼──────────────────────────────────────────────────────────────────┤
│   q │ Quit                                                             │
└─────┴──────────────────────────────────────────────────────────────────┘
```

Two things make it more than a wrapper. Every choice **prints the command line it is equivalent to** before it runs, so anyone using the menu graduates to scripting without being taught. And the last result is **held**, so saving is a separate decision from producing: press `s` once you have seen the answer and choose HTML, JSON or CSV then.

Blank always means go back. A wrong answer costs the answer, not the session. Ctrl-C returns to the menu.

### Finding the name to type

The database holds 28,951 product entries under 814 vendor spellings, and scoring needs the spelling the advisory used.

```
$ retrust search S7-1500
```

```
4 products matching 'S7-1500', strongest match first:

  Siemens / SIMATIC S7-1500 Software Controller
    tokens        --                      20 advisories
  Siemens / SIMATIC S7-1500 CPU 1518-4 PN/DP MFP (6ES75...
    tokens        6ES7518-4AX00-1AB0      16 advisories
```

Every hit says which test matched it: `exact`, `prefix`, `tokens`, `substring`, or `similar 0.86` for an edit-distance match. A misspelling gets a shortlist rather than nothing, and `score` falls back to the same suggestions when it cannot resolve what you typed.

### Scoring one product

```
$ retrust score --order-number 6ES7518-4AX00-1AB0 --version 3.1.6
```

```
AVOID  39.1/100   Siemens SIMATIC S7-1500 CPU 1518-4 PN/DP MFP
  matched by order_number (confidence 0.98), 32 advisory product(s), 1011 CVE(s)

  HARD GATE: Known exploited vulnerability
    8 CVE(s) in CISA KEV catalogue
    source: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

  Exploitation         0.0   coverage 100%
      - 8 CVE(s) in CISA KEV
      - peak EPSS 1.000
  Severity            41.0   coverage 100%
      - highest CVSS 9.8
      - 21/1011 rated critical (9.0+), 264 high
```

### Comparing candidates for one decision

```
$ retrust compare --candidate "ABB|AC 800M" \
      --candidate "Schneider Electric|Modicon M340" \
      --candidate "Hikvision|IP Camera" --html decision.html
```

```
CANDIDATE                          VERDICT       SCORE  CVES  ROBUST  NOTES
ABB AC 800M                        PREFER         81.5    10    91%
Schneider Electric Modicon M340    PREFER         77.2    21    77%
Hikvision IP Camera                AVOID           --     -     -    Named on a covered list
```

The candidate string is pipe-separated: `Vendor|Product|Version|OrderNumber`, and everything after the vendor is optional.

### Reading the result

| COLUMN | WHAT IT MEANS |
|---|---|
| VERDICT | **PREFER** ≥70, **CONDITIONAL** ≥40, **AVOID** below, **NOT ASSESSED** when it could not resolve the product |
| SCORE | The weighted composite, 0–100, higher is better |
| CVES | Findings in scope. Never scored directly — see the rules below |
| ROBUST | The share of random weightings giving the same verdict |
| NOTES | The gate that decided it, if one did |

> ROBUST IS THE COLUMN MOST WORTH READING
>
> The usual objection to any composite score is that its weights were invented. ReTrust measures that rather than arguing about it: it samples hundreds of weightings from across the whole simplex and reports how often the verdict survives. A verdict holding under 91% of weightings is a result. One holding under 77% is a judgement call, and the tool says so instead of handing you a false precision.

### A whole bill of materials

```
$ retrust batch bom.csv --json results.json --csv results.csv --html review.html
```

Column names are matched loosely, so `Manufacturer`, `Part Number` and `Firmware Version` all work without reshaping a procurement export. **The exit code is the point**: it makes this a gate rather than a report somebody has to read.

| --FAIL-ON | EXITS NON-ZERO WHEN |
|---|---|
| `avoid` (default) | a candidate is disqualified |
| `unassessed` | also when a candidate could not be assessed at all |
| `never` | never; just report |

## 5 The rules that keep it honest

- **Raw CVE counts are never scored.** A vendor that discloses diligently would rank below one that stays quiet — exactly backwards.
- **A product it cannot resolve gets no score at all.** Every pillar reads "no CVEs found" as good news, so an unresolvable product would otherwise score near 100 and top the comparison. **NOT ASSESSED** sorts below **AVOID**.
- **Missing certification is never a penalty.** Most OT products are never submitted, so absence says nothing. A certificate can only add.
- **Unparseable version ranges stay in scope and are flagged**, never assumed safe.
- **Sanctions screening never fuzzy-matches.** Wrongly flagging a real manufacturer is the worst error this tool could make, so it matches exact identity-preserving names only.
- **No advisories is not evidence of safety.** It may simply mean nobody has published.

## 6 Going further

| QUESTION | COMMAND |
|---|---|
| What does the index hold on this supplier? | `retrust vendor "Moxa"` |
| This scored AVOID — what else is in the family? | `retrust alternatives --vendor V --product P` |
| What buying it commits me to operationally | `retrust ssvc --vendor V --product P --exposure open --automatable yes --human-impact high` |
| Has this probably been exploited already? | `retrust lev --vendor V --product P` |
| What changed since we approved this list? | `retrust diff approved.json` |
| How much does the verdict depend on the weights? | `retrust sensitivity --vendor V --product P` |
| Reproduce the published accuracy figures | `retrust eval --sample 4000` |
| Is this installation current enough to trust? | `retrust doctor` |
| Score the components of an integrator's SBOM | `retrust batch system-bom.json` |
| Does the score predict anything? | `retrust backtest` |
| Does that answer depend on the cutoff date? | `retrust backtest --sweep` |
| Pin the data for a reproducible result | `retrust snapshot --note "Q4 review"` |
| Tab completion | `eval "$(retrust completion bash)"` |

### Accuracy, and checking it yourself

Every figure below is recomputed from your own database by `retrust eval`. None of them has to be taken on trust.

| MEASUREMENT | RESULT |
|---|---|
| Version ranges decided deterministically | 89.1% of 28,651 |
| … of ranges that *can* be decided from a version string | 90.5% |
| Product resolution precision (n = 4,000) | 99.9% |
| Product resolution recall (n = 4,000) | 99.9% |

These measure resolving a *named* product to its advisories. They are not device-fingerprinting accuracy; identifying equipment from passive network traffic is a much harder problem and a different question.

### Where the data comes from

| SOURCE | WHAT IT PROVIDES |
|---|---|
| CISA ICS advisories (CSAF 2.0) | authoritative product→CVE mappings |
| CISA KEV | confirmed exploitation, ransomware linkage |
| FIRST EPSS | exploitation probability, and the history LEV composes |
| ISASecure / Common Criteria | IEC 62443 and CC certificates |
| Consolidated Screening List, FCC Covered List | sanctions and covered entities |
| CERT/CC SSVC, NIST CSWP 41 | the deployer decision tree, and the LEV metric |

ReTrust redistributes no vendor data. It reads these at build time and cites each one in every report footer, so a result stays interpretable months later. Screening and certification results are reproductions of what those sources publish: decision support for a buyer, not a legal determination. Verify any gate against the cited source before acting on it.

---